2026 SHENZHEN INTERNATIONAL FINTECH COMPETITION (FINTECHATHON) • TOPIC F: AGENT WALLET

Autonomous Agent Wallet & Deterministic Risk Control Plane

Separating AI conversational reasoning from cryptographic execution via a 7-stage fail-closed policy engine, quantitative 0-100 risk scoring, and live Ethereum Sepolia settlement.

6
Autonomous tools
Portfolio, simulation, single and batch ETH settlement

3
Permission tiers
Read-only, approve-all and limited-auto governance

50/50
Passing unit tests
Pytest unit and adversarial security tests

Live
Ethereum Sepolia
Verified on-chain EIP-1559 transactions

Presenter: **Sadman Sakib** • American International University-Bangladesh (AIUB)

GitHub: https://github.com/Crux-15/agent-wallet

MOTIVATION & PROBLEM STATEMENT

Why Naive AI Wallets Fail in Finance

Giving an LLM direct custody of private keys creates catastrophic security exposure

THE PROBLEM

Naive AI Wallet Failure Modes

Prompt Injection Drain

Malicious text tricks the LLM into signing unauthorized transfers.

Hallucinated Math

Floating-point errors, or hallucinated addresses and amounts.

Velocity Smurfing

A forbidden transfer is split into many small transfers.

Fee & Reserve Drain

Executing during gas spikes, or draining 100% of the funds.

OUR SOLUTION

Bounded Financial Agency

Zero Key Exposure

Gemini never touches PRIVATE_KEY; it only requests tools.

7-Stage Deterministic Policy Engine

Every transfer is vetted with exact Python Decimal math.

Persistent 24h Rolling Cap

Saved to logs/policy_state.json, so it survives restarts.

Human-in-the-Loop Gate

Medium transfers pause for supervisor approval.

SYSTEM ARCHITECTURE

Four-Layer System Architecture

Defense-in-depth isolation between user input, LLM planning, policy verification, and blockchain signing

Supervisor UI Layer

`app.py & agent.py`

- Streamlit Web Control Center + CLI
- Live KPI metrics: Total ETH, Spendable ETH, Gas Gwei
- One-click human Approve / Reject
- Preflight dry-run simulator panel

Cognitive AI Layer

`agent.py`

- Gemini function-calling loop (MAX_ROUNDS = 5)
- Failover across gemini-2.5-flash and 2.0-flash
- Local regex fallback router keeps it working during API rate limits or outages

Guard & Policy Brain

`executor.py & policy.py`

- Whitelists 6 strictly typed tools
- 7-stage policy check and risk scorer (0-100)
- Enforces Permission Tiers 0, 1 and 2
- Sanitized telemetry to logs/audit.jsonl

Execution Adapters

`adapters/`

- Abstract ExecutionAdapter interface
- MockAdapter: instant sandbox for CI tests
- ChainAdapter: Sepolia EIP-1559 signer (Web3.py) with 20% gas buffer

INTENT SIDE user input and LLM planning. No keys, no signing.

EXECUTION SIDE deterministic policy verification and signing.

TASK COMPLETION CRITERION • 40% WEIGHT

Six-Tool Asset Management Suite

Six structured tools for portfolio awareness, preflight simulation, and settlement

get_portfolio_status

READ

Total ETH, 0.002 ETH reserve floor, spendable liquidity, remaining 24h cap, and live gas health (SAFE vs HIGH_FEE_ALERT).

simulate_transfer

SIMULATE

Zero-gas preflight dry run returning would_status, 0-100 risk score, estimated gas, and projected balance.

send_eth

TRANSFER

Single ETH transfer gated by the policy engine and human supervisor approval. Spend is recorded after receipt.

batch_send_eth

TRANSFER

Multi-recipient settlement (up to 5 transfers), with individual policy enforcement for every item.

get_policy_limits

READ

Inspects the active tier, caps (0.01 ETH per-tx, 0.05 ETH daily), reserve floor, and allowlist.

get_balance

READ

Queries the wallet balance on the Mock sandbox or on live Ethereum Sepolia.

SECURITY & COMPLIANCE CRITERION • 30% WEIGHT

Three-Tier Permission Governance

Empirically verified policy tiers with deterministic fail-closed enforcement

PERMISSION TIER	MODE NAME	AUTONOMOUS AGENT CAPABILITIES	TEST RESULT `tier_demo.py`
Tier 0	READ_ONLY	Read and simulate only. All transfers are denied.	DENIED human_asked = no
Tier 1	APPROVE_ALL	100% of outgoing transfers require human approval.	SENT AFTER HUMAN YES human_asked = yes
Tier 2 DEFAULT	LIMITED_AUTO	Auto-executes allowlisted transfers up to 0.002 ETH; escalates 0.002 to 0.01 ETH to a human.	AUTO SENT human_asked = no

7-STAGE FAIL-CLOSED POLICY PIPELINE • EVERY TRANSFER, IN THIS ORDER

1. Tier lock
2. Address validation
3. Decimal positivity
4. Allowlist check
5. Per-tx and 24h caps
6. Reserve and gas guard
7. Human escalation

PER-TX CAP	24H ROLLING CAP	RESERVE FLOOR	GAS CEILING	SPEND ACCOUNTING
0.01 ETH	0.05 ETH	0.002 ETH	50 Gwei	Commit-after-receipt

CORE ALGORITHM & INNOVATION • 30% WEIGHT

Quantitative Risk Scoring, 0 to 100

Every proposed transaction is scored across five risk dimensions before execution

$$R = \min(100,\ R_{addr} + R_{size} + R_{thresh} + R_{vel} + R_{gas})$$

R_addr

+60

Recipient trust

Address is not on the allowlist, or fails the address regex.

R_size

Scaled

Transfer size

int((amount / per-tx cap) × 30), so it grows with size.

R_thresh

+15

Approval threshold

Transfer is above the 0.002 ETH auto-approval limit.

R_vel

+35

24h velocity breach

24h spend plus amount would exceed the 0.05 ETH cap.

R_gas

+25

Network fee spike

Live gas price is above the 50 Gwei ceiling.

REAL SEPOLIA EXAMPLES

1 / 100 LOW
0.0005 ETH, approved recipient

21 / 100 MEDIUM
0.0022 ETH, approved recipient

61 / 100 HIGH, denied
0.0005 ETH, unknown address



Autonomous execution allowed in Tier 2 (up to 0.002 ETH)

Pauses for human supervisor approval (needs_approval)

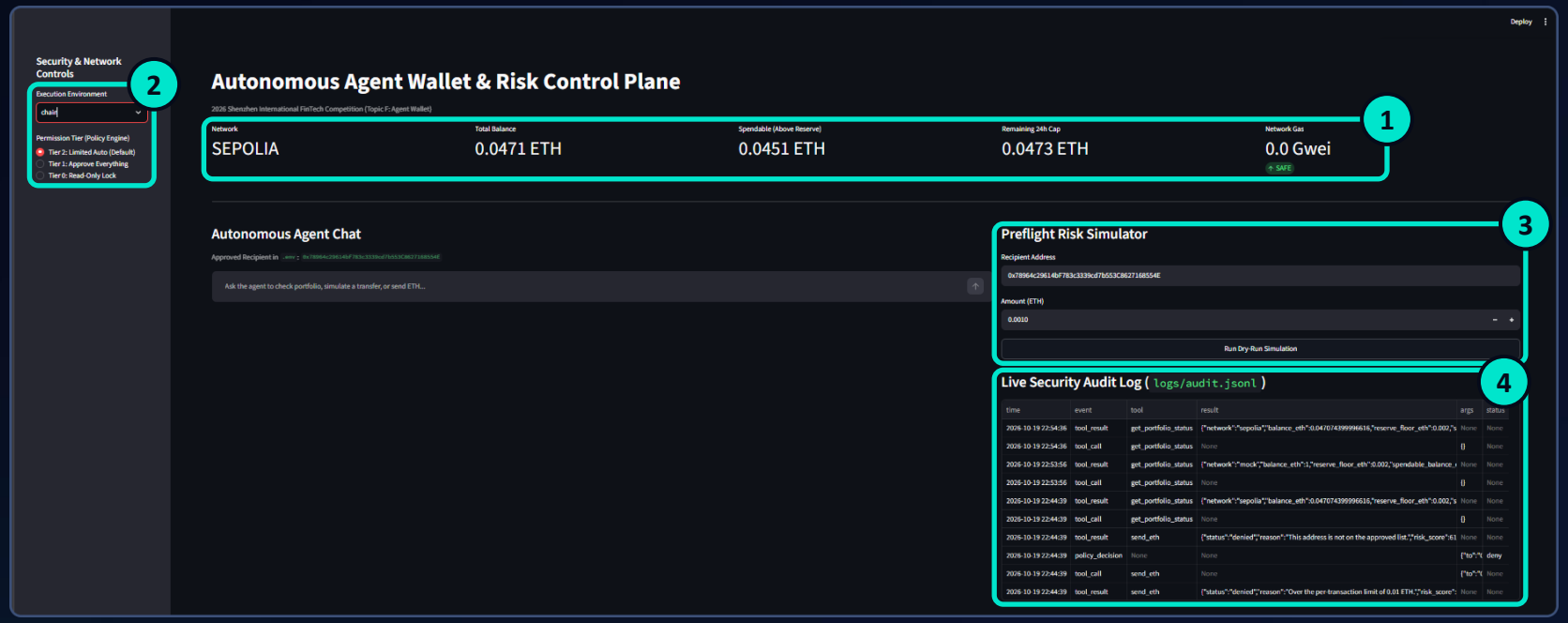
Blocked if a cap or gas limit is breached, or escalated to the human operator

Immediate fail-closed denial, logged to audit.jsonl

USER INTERACTION & EXPLAINABILITY

Interactive Web Control Center

Live Ethereum Sepolia telemetry, preflight dry-run simulator, tier switcher, and audit trail



1 Live KPI ribbon
Network, balance, spendable, 24h cap and live gas at a glance

2 Tier selector
Switch mock or chain, or lock into Tier 0 Read-Only instantly

3 Preflight Risk Simulator
Dry-run a transfer and see its risk before anything is signed

4 Live Audit Log
Structured JSONL events from logs/audit.jsonl, in real time

Human approval banner
Medium transfers show one-click Approve / Reject buttons

TOTAL BALANCE

0.0471 ETH

Sepolia wallet

SPENDABLE

0.0451 ETH

Total minus the 0.002 ETH reserve

REMAINING 24H CAP

0.0473 ETH

0.05 minus 0.0005 minus 0.0022

EXECUTION EVIDENCE • CHECKLIST ITEM 06

Real On-Chain Execution Evidence

Approved recipient (both transfers): `0x78964c29614bF783c3339cd7b553C8627168554E`

TX #1 Auto-approved (Tier 2)

0.0005 ETH | Risk 1/100 LOW | SUCCESS

TX HASH • BLOCK 11949435 • OCT 19, 2026 16:44:00 UTC

0xd03fff8dc8ba123539f97cab7dd456c9487535c446df01674aee8cee6524a0a4

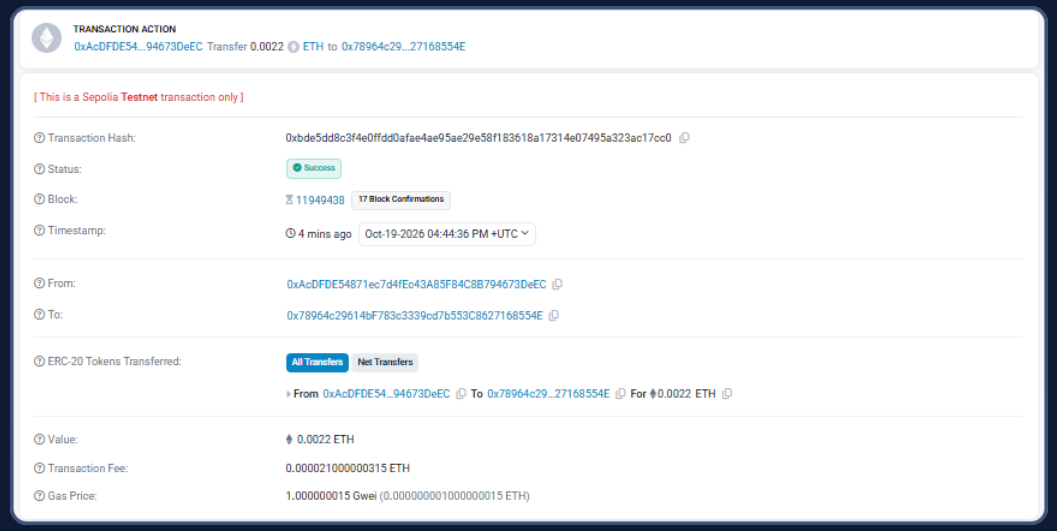


TX #2 Human-approved (supervisor)

0.0022 ETH | Risk 21/100 MEDIUM | SUCCESS

TX HASH • BLOCK 11949438 • OCT 19, 2026 16:44:36 UTC

0xbde5dd8c3f4e0ffdd0afae4ae95ae29e58f183618a17314e07495a323ac17cc0



ENGINEERING RIGOR • CHECKLIST ITEM 05

50 Tests & Security Self-Assessment

Comprehensive unit test coverage paired with a transparent production remediation roadmap

50 / 50

pytest tests passing (100% pass rate)

5 — `test_adapters.py`
Starting balance, transfer accounting, overspend prevention, zero-amount rejection, gas price reporting.

23 — `test_policy.py`
Tier 0/1/2 rules, regex validation, 24h rolling window, split-payment blocking, disk persistence, reserve floor, gas ceiling, risk scoring.

15 — `test_executor.py`
Human approval gate, self-approval immunity ("approved": True injection blocked), simulation safety, batch transfers, audit log integrity.

7 — `test_agent.py`
Tool routing and adversarial prompt-injection defense.

6 Known Risks & Production Roadmap

1	**Local approval channel (terminal or Streamlit button)**	→ WebAuthn passkey or hardware-wallet signatures
2	**Plaintext .env key (git-ignored)**	→ HSM, cloud KMS, or ERC-4337 session keys
3	**Local JSON spend state (policy_state.json)**	→ On-chain spend limits via a smart-contract module
4	**Static allowlist loaded from .env**	→ Admin-signed on-chain registry, time-locked additions
5	**Sepolia testnet only**	→ Mainnet reorg-depth checks and Flashbots Protect RPC
6	**External cloud LLM API (free-tier Gemini)**	→ Zero-data-retention endpoint or local open-weights model

CONCLUSION & SUBMISSION SUMMARY

Summary & Rubric Alignment

Ready for live review with full source code, 50 unit tests, and verifiable on-chain proof

40%

Task Completion

Full autonomous wallet lifecycle: portfolio health, preflight simulation, single and batch ETH transfers, and real Sepolia settlement.

30%

Security & Compliance

3 permission tiers, 7-stage fail-closed policy engine, persistent 24h spend cap, reserve floor, gas ceiling guard, and sanitized JSONL audit trail.

30%

Innovation & Interaction

Quantitative 0-100 risk scoring, Streamlit Web Control Center, and a resilient Gemini plus local fallback router.

+5

On-Chain Bonus (0-5 pts)

Two confirmed Sepolia transactions, one auto-approved and one human-approved, with verifiable hashes.

Public GitHub Repository & Verification

Clone and run `python -m pytest -q` (50 passed) or `streamlit run app.py`

https://github.com/Crux-15/agent-wallet

Thank you to the Organizing Committee and Judges (Tsinghua PBCSF & WeBank)